

نظم المعلومات الإدارية

Management Information Systems

المحاضرة الثانية عشرة: أمن نظم المعلومات

Information Systems Security

الدكتور إياد زوكار

- لماذا تكون نظم المعلومات عرضة للتدمير والخطأ وإساءة المعاملة؟
- ما قيمة نظام الأمن والتحكم بالنسبة للمنظمة؟
- ما هي مكونات الإطار التنظيمي للأمن والتحكم؟
- ما هي أهم الأدوات والتقنيات للحفاظ على موارد المعلومات؟

1. الأخطاء وإمكانية التدمير والخطأ وسوء الاستخدام في نظم المعلومات
2. أدوات وتقنيات حماية موارد المعلومات

1. الأخطاء وإمكانية التدمير والخطأ وسوء الاستخدام في نظم المعلومات

1. الأمن والضوابط
2. لماذا تكون الأنظمة عرضة للخطر؟
3. البرامج الضارة: الفيروسات والديدان وأحصنة طروادة وبرامج التجسس
4. قرصنة وجرائم الكمبيوتر
5. التهديدات الداخلية: الموظفون
6. الثغرات البرمجية

1. الأخطاء وإمكانية التدمير والخطأ وسوء الاستخدام في نظم المعلومات

1. الأمن والضوابط

• الأمن Security

✓ السياسات والإجراءات والتدابير التقنية المستخدمة لمنع الوصول غير المصرح لهم أو التغيير أو السرقة أو الأضرار المادية لنظم المعلومات

• الضوابط Controls

✓ الطرق والسياسات والإجراءات التنظيمية التي تضمن سلامة أصول المؤسسة ودقة وموثوقية سجلاتها والالتزام التشغيلي بمعايير الإدارة

1. الأخطاء وإمكانية التدمير والخطأ وسوء الاستخدام في نظم المعلومات

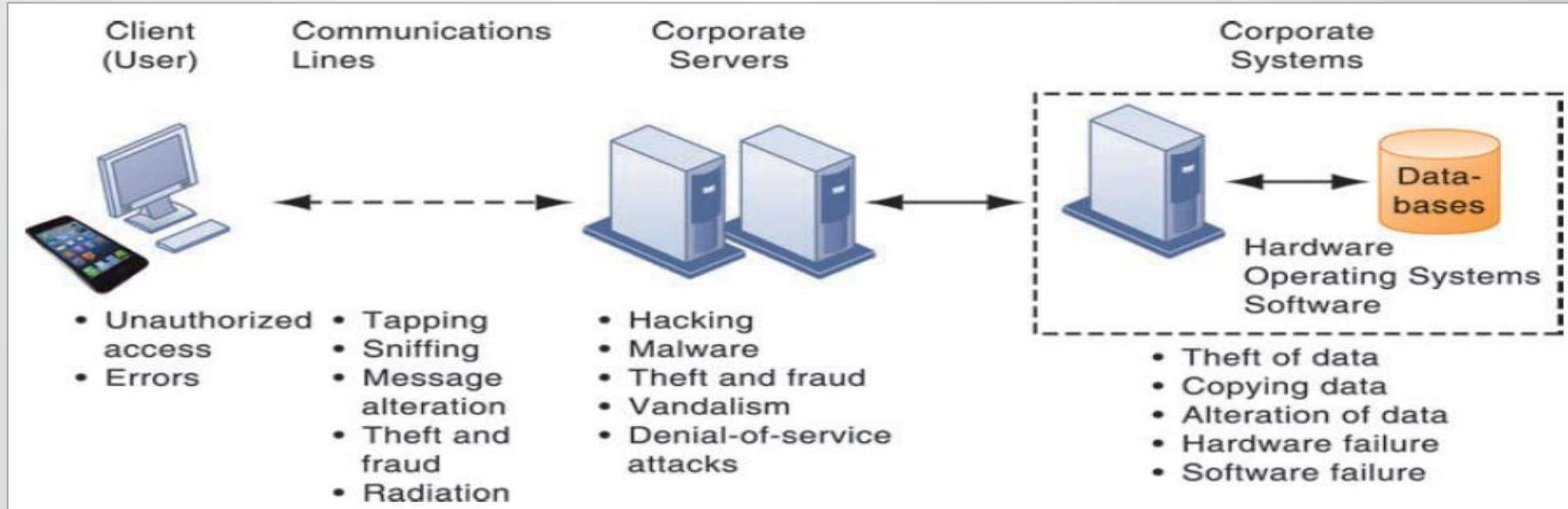
2. لماذا تكون الأنظمة عرضة للخطر؟

- تخزين كميات كبيرة من البيانات في شكل إلكتروني
✓ تكون عرضة لأنواع كثيرة من التهديدات
- يتم ربط نظم المعلومات في مواقع مختلفة من خلال شبكات الاتصالات
✓ الوصول غير المصرح به أو سوء الاستخدام أو الاحتيال في أي نقطة وصول في الشبكة
- في بيئة الحوسبة للعميل/المخدم متعدد الطبقات توجد ثغرات أمنية في كل طبقة وفي الاتصالات بين الطبقات
✓ يتسبب المستخدمون في طبقة العميل في حدوث ضرر عن طريق إدخال الأخطاء أو الوصول إلى الأنظمة دون تصريح
✓ الوصول إلى البيانات المتدفقة عبر الشبكات أو سرقة البيانات القيمة أثناء الإرسال أو تغيير البيانات دون تصريح
✓ يتسبب الإشعاع في تعطيل الشبكة في نقاط مختلفة
✓ يشن المتطفلون هجمات رفض الخدمة أو البرامج الضارة لتعطيل تشغيل مواقع الويب
✓ سرقة بيانات الشركة المخزنة في قواعد البيانات أو الملفات أو إتلافها أو تغييرها
✓ تعطل أجهزة الكمبيوتر أو عدم تهيئتها بشكل صحيح أو تلفها بسبب الاستخدام غير السليم أو الأعمال الإجرامية
✓ تتسبب الأخطاء في البرمجة أو التثبيت غير الصحيح أو التغييرات غير المصرح بها في فشل برنامج الكمبيوتر
✓ يؤدي انقطاع التيار الكهربائي أو الفيضانات أو الحرائق أو الكوارث الطبيعية الأخرى إلى تعطيل أنظمة الكمبيوتر

1. الأخطاء وإمكانية التدمير والخطأ وسوء الاستخدام في نظم المعلومات

2. لماذا تكون الأنظمة عرضة للخطر؟

• التهديدات الأكثر شيوعاً ضد نظم المعلومات المعاصرة



1. الأخطاء وإمكانية التدمير والخطأ وسوء الاستخدام في نظم المعلومات

2. لماذا تكون الأنظمة عرضة للخطر؟

• الثغرات الأمنية في الإنترنت

- ✓ الإنترنت أكثر عرضة من الشبكات الداخلية لأنها مفتوحة فعلياً لأي شخص
- ✓ يمكن أن يكون تأثير الانتهاكات واسع النطاق
- ✓ عندما تكون الإنترنت جزءاً من شبكة الشركة، تصبح أنظمة معلومات المؤسسة أكثر عرضة لانتهاكات أشخاص من خارج الشركة
- ✓ تقنية VoIP أكثر عرضة للخطر من شبكة الصوت التقليدية
- ✓ البريد الإلكتروني Email والمراسلة الفورية IM وبرامج مشاركة الملفات P2P

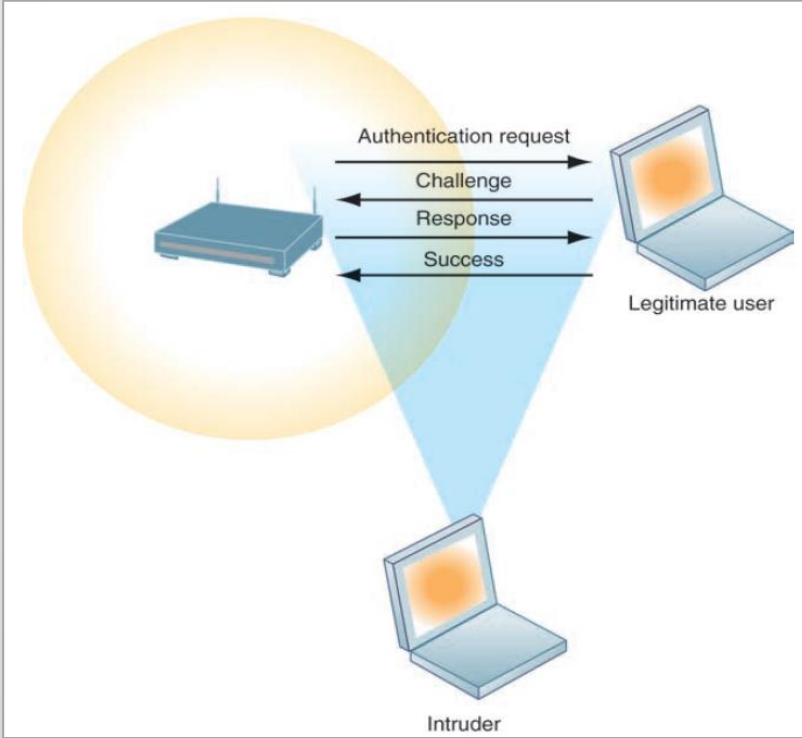
• التحديات الأمنية اللاسلكية

1. الأخطاء وإمكانية التدمير والخطأ وسوء الاستخدام في نظم المعلومات

2. لماذا تكون الأنظمة عرضة للخطر؟

• التحديات الأمنية اللاسلكية

- ✓ تتعرض شبكات Bluetooth و Wi-Fi للتسلل والقرصنة عبر أجهزة التنصت
- ✓ يمكن اختراق شبكات المناطق المحلية LAN التي تستخدم معيار 802.11 بسهولة من قبل جهات خارجية مزودة بأجهزة الكمبيوتر المحمولة والبطاقات اللاسلكية والهوائيات الخارجية وبرامج القرصنة
- ✓ هناك أدوات للكشف عن الشبكات غير المحمية ومراقبة حركة مرور الشبكة
- ✓ تم تصميم تقنية إرسال Wi-Fi لتسهيل العثور على المحطات والتواصل فيما بينها
 - يتم بث معرفات مجموعة الخدمات SSID التي تحدد نقاط الوصول بشكل متكرر
 - يمكن التقاط هذه المعرفات بسهولة إلى حد ما بواسطة برامج اكتشاف المتطفلين
 - يمكن للمتسللين التقاط أسماء وكلمات مرور المستخدمين المستهترين



1. الأخطاء وإمكانية التدمير والخطأ وسوء الاستخدام في نظم المعلومات

3. البرامج الضارة: الفيروسات والديدان وأحصنة طروادة وبرامج التجسس

• البرامج الضارة Malware

✓ برامج تشكّل مجموعة متنوعة من التهديدات مثل فيروسات الكمبيوتر والديدان وأحصنة طروادة

• فيروس الكمبيوتر Computer Virus

✓ برنامج احتيالي يقوم بإرفاق نفسه ببرامج أو بملفات بيانات أخرى ليتم تنفيذه، وعادة ما يكون ذلك بدون معرفة المستخدم أو إذنه

• الديدان Worms

✓ برامج كمبيوتر مستقلة تقوم بنسخ نفسها من كمبيوتر إلى أجهزة كمبيوتر أخرى عبر شبكة

• المتسللون Hackers

✓ أشخاص يمكنهم القيام بأي شيء ممكن في الهاتف الذكي على أي جهاز مرتبط بالإنترنت
✓ طلب ملفات ضارة دون تدخل من المستخدم وحذف الملفات أو إرسالها وتثبيت البرامج التي تعمل في الخلفية لمراقبة إجراءات المستخدم

• حصان طروادة Trojan Horse

✓ برنامج يبدو حميداً ولكنه يقوم بشيء آخر غير المتوقع
✓ لا يُعتبر حصان طروادة فيروساً في حد ذاته لأنه لا يتكرر، ولكنه غالباً ما يكون وسيلة لإدخال الفيروسات أو أكواد خبيثة في الكمبيوتر

1. الأخطاء وإمكانية التدمير والخطأ وسوء الاستخدام في نظم المعلومات

3. البرامج الضارة: الفيروسات والديدان وأحصنة طروادة وبرامج التجسس

• هجمات حقن تعليمات الاستعلام SQL Injection Attacks

✓ برامج ضارة تشكل تهديداً كبيراً، تستفيد من نقاط الضعف والثغرات الأمنية في برامج تطبيق الويب سيئة الترميز لإدخال تعليمات برمجية ضارة في أنظمة وشبكات الشركة

• برامج الفدية Ransomware

✓ برامج ضارة تحاول ابتزاز الأموال من المستخدمين عن طريق التحكم في أجهزة الكمبيوتر الخاصة بهم أو عرض رسائل منبثقة مزعجة

• برامج التجسس Spyware

✓ برامج ضارة تقوم بالتجسس على أجهزة الكمبيوتر أو الأجهزة المحمولة، حيث تقوم بتنشيط نفسها بشكل خفي لمراقبة نشاط المستخدم لتصفح الويب وعرض الإعلانات

• مسجل لوحة المفاتيح Keylogger

✓ برنامج ضار يقوم بتسجيل كل ضغطة على لوحة المفاتيح التي يتم إجراؤها على جهاز كمبيوتر لسرقة الأرقام التسلسلية للبرامج أو لشن هجمات على الإنترنت أو للوصول إلى الحسابات

1. الأخطاء وإمكانية التدمير والخطأ وسوء الاستخدام في نظم المعلومات

4. قرصنة وجرائم الكمبيوتر

- المتسلل Hacker: الشخص الذي ينوي الوصول غير المصرح به إلى نظام الكمبيوتر
- المهكر Cracker: المتسلل بنية إجرامية
- الانتحال Spoofing

✓ عندما يحاول المتسللون إخفاء هوياتهم الحقيقية باستخدام عناوين البريد الإلكتروني المزيفة أو التكرار كشخص آخر
✓ إعادة توجيه رابط ويب إلى عنوان مختلف عن العنوان المقصود، حيث ينتحل هذا الموقع هوية الوجهة المقصودة

• التعقب Sniffing

✓ نوع من برامج التنصت التي تراقب المعلومات التي تنتقل عبر الشبكة

• هجمات الحرمان من الخدمة Denial-of-Service (DoS) Attack

✓ يقوم المتسللون بإغراق مخدم الشبكة أو مخدم الإنترنت الخادم بعدة آلاف من الاتصالات الكاذبة أو طلبات الخدمات إلى تعطيل الشبكة
✓ هجمات الحرمان من الخدمة الموزعة Distributed Denial-of-Service (DDoS) Attack

1. الأخطاء وإمكانية التدمير والخطأ وسوء الاستخدام في نظم المعلومات

COMPUTERS AS TARGETS OF CRIME

- Breaching the confidentiality of protected computerized data
- Accessing a computer system without authority
- Knowingly accessing a protected computer to commit fraud
- Intentionally accessing a protected computer and causing damage negligently or deliberately
- Knowingly transmitting a program, program code, or command that intentionally causes damage to a protected computer
- Threatening to cause damage to a protected computer

COMPUTERS AS INSTRUMENTS OF CRIME

- Theft of trade secrets
- Unauthorized copying of software or copyrighted intellectual property, such as articles, books, music, and video
- Schemes to defraud
- Using email or messaging for threats or harassment
- Intentionally attempting to intercept electronic communication
- Illegally accessing stored electronic communications, including email and voice mail
- Transmitting or possessing child pornography by using a computer

4. قراصنة وجرائم الكمبيوتر

• جريمة الكمبيوتر Computer Crime

- أي انتهاكات للقانون الجنائي تتطوي على معرفة بتكنولوجيا الكمبيوتر لارتكابها أو التحقيق فيها أو ملاحقتها قضائياً

1. الأخطاء وإمكانية التدمير والخطأ وسوء الاستخدام في نظم المعلومات

4. قرصنة وجرائم الكمبيوتر

• سرقة الهوية Identity Theft

✓ جريمة يحصل فيها المحتال على بعض المعلومات الشخصية، مثل أرقام الضمان الاجتماعي أو أرقام رخصة القيادة أو أرقام بطاقات الائتمان، لانتحال شخصية شخص آخر

• التصيد الاحتيالي Phishing

✓ شكل من أشكال الخداع يتضمن إنشاء مواقع ويب مزيفة أو إرسال رسائل بريد إلكتروني تشبه تلك الخاصة بالأنشطة التجارية المشروعة لطلب البيانات الشخصية السرية من المستخدمين

• التصيد المستهدف Spear Phishing

✓ تظهر الرسائل وكأنها واردة من مصدر موثوق به

• التوائم الشريرة Evil Twins

✓ شبكات لاسلكية تتظاهر بأنها تقدم اتصالات Wi-Fi موثوقة بالإنترنت، مثل تلك الموجودة في صالات المطارات أو الفنادق أو المقاهي، وتبدو شبكة وهمية مماثلة لشبكة عامة شرعية، ومن خلالها يحاول المحتالون التقاط كلمات المرور أو أرقام بطاقات الائتمان

1. الأخطاء وإمكانية التدمير والخطأ وسوء الاستخدام في نظم المعلومات

4. قراصنة وجرائم الكمبيوتر

• التزيف Pharming

✓ إعادة توجيه المستخدمين إلى صفحة ويب وهمية مزيفة، حتى عندما يكتب الشخص عنوان صفحة الويب الصحيحة في متصفحه

• النقر الاحتيالي Click Fraud

✓ عند قيام أحد الأفراد أو أحد برامج الكمبيوتر بالنقر فوق إعلان عبر الإنترنت عن طريق الاحتيال دون أي نية لمعرفة المزيد عن المعلن أو إجراء عملية شراء

• الحرب الإلكترونية Cyberwarfare

✓ هو نشاط ترعاه الدولة ويهدف إلى شل وهزيمة دولة أخرى عن طريق اختراق أجهزة الكمبيوتر أو الشبكات الخاصة بها للتسبب في الضرر والتعطيل. كما تشمل الحرب الإلكترونية الدفاع عن نفسها ضد هذه الأنواع من الهجمات. والحرب الإلكترونية أكثر تعقيداً من الحرب التقليدية

1. الأخطاء وإمكانية التدمير والخطأ وسوء الاستخدام في نظم المعلومات

5. التهديدات الداخلية: الموظفون

- إن قلة المعرفة لدى المستخدم هي السبب الأكبر لانتهاكات أمان الشبكة
- ينسى العديد من الموظفين كلمات المرور الخاصة بهم أو يسمحون لزملاء العمل باستخدامها
- الهندسة الاجتماعية Social Engineering
- ✓ يقوم المتسللون بخداع الموظفين للكشف عن كلمات المرور الخاصة بهم من خلال التظاهر بأنهم أعضاء شرعيون في الشركة وهم بحاجة إلى المعلومات

1. الأخطاء وإمكانية التدمير والخطأ وسوء الاستخدام في نظم المعلومات

6. الثغرات البرمجية

• أخطاء مخفية Bugs

- يساهم التعقيد المتزايد للبرمجيات وحجمها، بالإضافة إلى مطالب التسليم في الوقت المناسب في زيادة عيوب هذه البرمجيات أو الثغرات الأمنية
- الثغرات الأمنية تفتح الشبكات أمام المتسللين الذين يستغلون هذه الثغرات قبل أن يصبح البائع على دراية بالمشكلة ويسارع لإصلاحها
- تصحيحات Patches

2. أدوات وتقنيات حماية موارد المعلومات

1. إدارة الهوية والمصادقة
2. الجدران النارية وأنظمة كشف التسلل ومكافحة الفيروسات
3. تأمين الشبكات اللاسلكية
4. التشفير والبنية التحتية للمفتاح العام
5. ضمان توافر النظام
6. مشكلات الأمان للحوسبة السحابية والمنصة الرقمية للأجهزة المحمولة
7. ضمان جودة البرمجيات

2. أدوات وتقنيات حماية موارد المعلومات

1. إدارة الهوية والمصادقة

• المصادقة Authentication

- ✓ القدرة على التأكد من أن شخص ما هو فعلاً من يدّعي أنه هو. يتم إنشاء المصادقة باستخدام:
- ✓ كلمات مرور Passwords معروفة فقط للمستخدمين المصرح لهم
- ✓ الرمز المميز Token

➤ أداة ذكية صغيرة يتم احتواؤها عادةً على حلقات المفاتيح وتعرض رموز المرور التي تتغير بشكل متكرر

✓ البطاقة الذكية Smart Card

➤ بطاقة تحتوي على شريحة إلكترونية مهيّئة بإذن الوصول وغيرها من البيانات

➤ تُستخدم في أنظمة الدفع الإلكترونية

➤ يفسر جهاز القارئ البيانات الموجودة على البطاقة الذكية ويسمح أو يرفض الوصول إليها

✓ المصادقة البيومترية Biometric Authentication

➤ أنظمة تقرأ وتفسر السمات البشرية الفردية مثل بصمات الأصابع وقزحية العين والأصوات لمنح الوصول أو رفضه

• المصادقة الثنائية Two-Factor Authentication

- ✓ زيادة الأمان عن طريق التحقق من صحة المستخدمين من خلال عملية متعددة الخطوات

2. أدوات وتقنيات حماية موارد المعلومات

2. الجدران النارية وأنظمة كشف التسلل ومكافحة الفيروسات

• الجدران النارية Firewalls

✓ تمنع المستخدمين غير المصرح لهم من الوصول إلى الشبكات الخاصة

✓ مزيج من الأجهزة والبرمجيات التي تتحكم في تدفق حركة مرور على الشبكة الواردة والصادرة

• تصفية الحزمة Packet Filtering

✓ تقنية تقوم بفحص الحقول المحددة في رؤوس حزم البيانات التي تتدفق ذهاباً وإياباً بين الشبكة الموثوقة والإنترنت

• الفحص المتعلق بالحالة Stateful Inspection

✓ تقنية توفر حماية إضافية من خلال تحديد ما إذا كانت الحزم هي جزء من حوار مستمر بين المرسل والمستقبل

• ترجمة عنوان الشبكة Network Address Translation

✓ تقوم بإخفاء عناوين IP للكمبيوتر أو للأجهزة المضيفة الداخلية للمنظمة لمنع برامج التعقب من خارج جدار الحماية من التحقق من هذه العناوين واستخدام تلك المعلومات لاختراق الأنظمة الداخلية

2. أدوات وتقنيات حماية موارد المعلومات

2. الجدران النارية وأنظمة كشف التسلل ومكافحة الفيروسات

• تصفية وكيل التطبيق Application proxy filtering

✓ تقنية تقوم بفحص محتوى التطبيق ضمن الحزم. حيث يقوم مخدّم الوكيل بإيقاف حزم البيانات التي يتم إنشاؤها من خارج المنظمة وفحصها ثم تمريرها إلى الجانب الآخر من جدار الحماية

• أنظمة كشف التسلل Intrusion Detection Systems

✓ أدوات وخدمات لاكتشاف التسلل للحماية من حركة المرور المشتبه فيها على الشبكة ومحاولات الوصول إلى الملفات وقواعد البيانات

• برامج مكافحة الفيروسات Antivirus و برامج مكافحة التجسس Antispyware Software

✓ تمنع البرامج الضارة وتكتشفها وتزيلها، بما في ذلك فيروسات الكمبيوتر وديدان الكمبيوتر وأحصنة طروادة وبرامج التجسس والبرامج الإعلانية

• أنظمة إدارة التهديدات الموحدة Unified Threat Management

✓ بدمج عدة أدوات للأمن في جهاز واحد، بما في ذلك جدران الحماية والشبكات الخاصة الافتراضية وأنظمة الكشف عن التسلل وتصفية محتوى الويب وبرامج مكافحة البريد العشوائي

2. أدوات وتقنيات حماية موارد المعلومات

3. تأمين الشبكات اللاسلكية

- الخصوصية المكافئة للتوصيل السلكي (Wired Equivalent Privacy (WEP)

✓ لا يُعد فعالاً لأن مفاتيح التشفير الخاصة به سهلة نسبياً

- WPA2 أو Wi-Fi Protected Access 2

✓ يستخدم مفاتيح أطول بكثير تتغير باستمرار، مما يجعل من الصعب اختراقها

2. أدوات وتقنيات حماية موارد المعلومات

4. التشفير والبنية التحتية للمفتاح العام

• التشفير Encryption

✓ هو عملية تحويل النص العادي أو البيانات إلى نص مشفر لا يمكن قراءته بواسطة أي شخص آخر غير المرسل والمستقبل المقصود

• طبقة مآخذ التوصيل الآمنة (SSL) Secure Sockets Layer

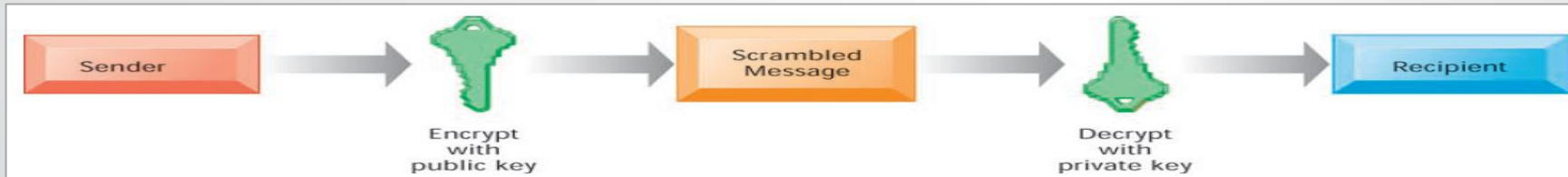
✓ تمكّن هذه الطبقة أجهزة الكمبيوتر العملية والمخدمات من إدارة أنشطة التشفير وفك التشفير أثناء اتصالهم مع بعضهم البعض أثناء جلسة ويب آمنة

• بروتوكول نقل النص التشعبي الآمن (S-HTTP) Secure Hypertext Transfer Protocol

✓ بروتوكول يستخدم لتشفير البيانات المتدفقة عبر الإنترنت، لكنه يقتصر على الرسائل الفردية

• تشفير المفتاح المتماثل Symmetric Key Encryption

✓ طريقة للتشفير يقوم فيها المرسل والمستقبل بإنشاء جلسة آمنة على الإنترنت عن طريق إنشاء مفتاح تشفير واحد وإرساله إلى المستقبل بحيث يتشارك كل من المرسل والمستقبل نفس المفتاح



2. أدوات وتقنيات حماية موارد المعلومات

4. التشفير والبنية التحتية للمفتاح العام

• التشفير بالمفتاح العمومي Public Key Encryption

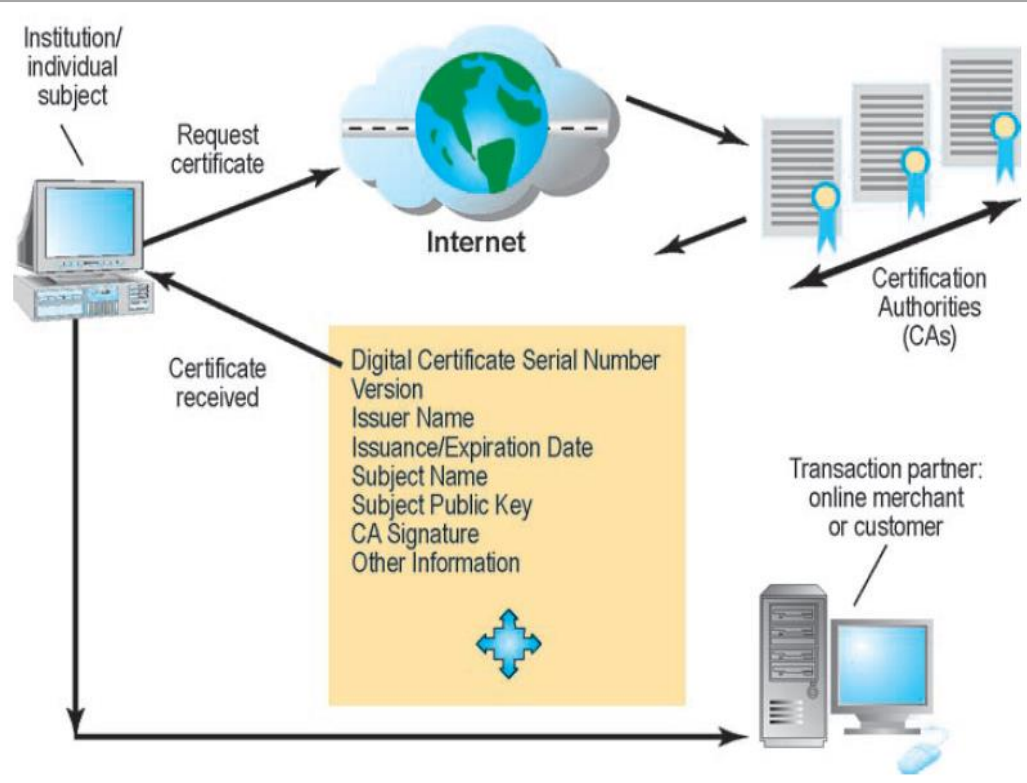
- ✓ شكل أكثر أمناً للتشفير يستخدم اثنين من المفاتيح: واحد مشترك أو عام والآخر خاص
- ✓ ترتبط المفاتيح رياضياً بحيث يمكن فك تشفير البيانات المشفرة بأحد المفتاحين باستخدام المفتاح الآخر

• الشهادات الرقمية Digital Certificates

- ✓ ملفات بيانات تُستخدم لإثبات هوية المستخدمين والأصول الإلكترونية لحماية المعاملات عبر الإنترنت
- ✓ ويستخدم نظام الشهادة الرقمية جهة خارجية موثوقة، تعرف باسم المرجع المصدق (Certificate Authority (CA، للتحقق من صحة هوية المستخدم

• البنية التحتية للمفتاح العام (PKI) Public key infrastructure

- ✓ استخدام التشفير بالمفتاح العام الذي يعمل مع المرجع المصدق، والآن تستخدم هذه البنية على نطاق واسع في مجال التجارة الإلكترونية



2. أدوات وتقنيات حماية موارد المعلومات

5. ضمان توافر النظام

• المعاملات عبر الإنترنت Online Transaction Processing

• أنظمة الكمبيوتر المتسامحة مع الأعطال Fault-tolerant computer systems

✓ تحتوي على مكونات احتياطية زائدة عن الحاجة من البرامج ومصادر الطاقة، والتي تعمل على خلق بيئة توفر خدمة مستمرة دون انقطاع

✓ تمنع تعطل العمل Downtime

• التحكم في حركة مرور الشبكة: فحص الحزم الدقيق Controlling Network Traffic: Deep Packet Inspection

✓ فحص ملفات البيانات وتصنيف المواد ذات الأولوية المنخفضة عبر الإنترنت مع تحديد أولوية أعلى لملفات الأعمال الهامة

• الاستعانة بمصادر خارجية للأمان Security Outsourcing

✓ موفري خدمات الأمان المُدارة (MSSPs) Managed Security Service Providers

✓ يقومون بمراقبة نشاط الشبكة وإجراء اختبار الثغرات الأمنية واكتشاف الاختراق

2. أدوات وتقنيات حماية موارد المعلومات

6. مشكلات الأمان للحوسبة السحابية والمنصة الرقمية للأجهزة المحمولة

• الأمن في السحابة Security in the Cloud

- ✓ المسؤولية عن حماية البيانات الحساسة لا تزال تقع على عاتق الشركة المالكة لتلك البيانات
- ✓ فهم كيفية قيام موفر الحوسبة السحابية بتنظيم خدماته وإدارة البيانات
- ✓ اتفاقية مستوى الخدمة (SLA) Service Level Agreement

• تأمين المنصات النقالة Securing Mobile Platforms

- ✓ ضد البرامج الضارة والسرقة والفقْدان والوصول غير المصرح به ومحاولات القرصنة
- ✓ تتطلب الأجهزة المحمولة التي تصل إلى أنظمة الشركة وبياناتها حماية خاصة
- ✓ تضمين سياسة أمان الشركة للأجهزة المحمولة

2. أدوات وتقنيات حماية موارد المعلومات

7. ضمان جودة البرمجيات

- تحسين جودة وموثوقية النظام من خلال استخدام مقاييس البرامج واختبارها بشكل دقيق
- الاختبار المبكر والمنتظم والشامل

أمن نظم المعلومات

1. الأخطاء وإمكانية التدمير والخطأ وسوء الاستخدام في نظم المعلومات

2. أدوات وتقنيات حماية موارد المعلومات

نظم المعلومات الإدارية

Management Information Systems

نهاية المحاضرة الثانية عشرة: أمن نظم المعلومات

Information Systems Security

الدكتور إياد زوكار